

# Unprotected Admin Functionality with Unpredictable URL

## Lab Information

| Field         | Value                 |
|---------------|-----------------------|
| Category      | Access Control        |
| Difficulty    | Apprentice            |
| Vulnerability | Broken Access Control |

---

## Summary

This lab demonstrates a **Broken Access Control** vulnerability where the administrator panel is located at an unpredictable URL. Although the endpoint is not publicly linked, its location is unintentionally disclosed within the application's client-side source code. Since no server-side authorization checks are enforced, any user who discovers the endpoint can access the administrator panel.

---

## Objective

Discover the hidden administrator URL and delete the user **carlos**.

---

## Attack Scenario

The application attempts to protect the administrator interface by placing it at a non-guessable URL instead of enforcing proper authorization.

However, the hidden endpoint is exposed in the client-side JavaScript source code. Because client-side code is always accessible to users, an attacker can inspect the source, discover the administrator URL, and access privileged functionality without authorization.

---

## Steps to Reproduce

1. Browse the application homepage.
2. View the page source or inspect the loaded JavaScript files.
3. Search for references to administrator functionality.

4. Identify the following JavaScript statement:

```
adminPanelTag.setAttribute('href', '/admin-08q15o');
```

1. Navigate directly to the discovered administrator endpoint.
  2. Access the administrator panel.
  3. Delete the user **carlos**.
  4. Verify that the lab is solved.
- 

## Evidence

### Client-Side Information Disclosure

The application's JavaScript source exposed the administrator endpoint:

```
adminPanelTag.setAttribute('href', '/admin-08q15o');
```

### Privileged Functionality

The administrator panel was accessible without any server-side authorization checks.

---

## Security Impact

An attacker can inspect publicly available client-side code to discover hidden administrative endpoints. If the application fails to enforce authorization on the server, the attacker can perform privileged actions such as user deletion, configuration changes, or other administrative operations.

---

## Root Cause

The application relied on an unpredictable URL as the primary protection mechanism instead of implementing proper server-side authorization. Additionally, sensitive endpoint information was exposed within client-side JavaScript, making it accessible to any user.

---

## Remediation

- Enforce server-side authorization for all administrative functionality.
- Never rely on secret or unpredictable URLs as a security mechanism.
- Avoid exposing sensitive endpoints or privileged functionality in client-side code.
- Assume that all client-side resources are fully visible to attackers.

---

## Pentester's Notes

When administrative functionality is not immediately visible, inspecting the application's source code and JavaScript files is an effective reconnaissance technique. Client-side code should always be considered public because every browser downloads it. During testing, searching for keywords such as **admin**, **panel**, **delete**, **manage**, or **dashboard** may reveal hidden functionality.

---

## Key Takeaways

- Client-side code is never a secure place to hide sensitive information.
- Unpredictable URLs do not provide access control.
- Every privileged endpoint must validate user authorization on the server.
- Source code review is an essential part of web application reconnaissance.